

(b) Guía metodológica detallada de la Encuesta ISO/IEC 42001 – Ciberseguridad y Gestión de IA

1. Propósito de la encuesta

La encuesta tiene como propósito medir, de forma estructurada y comparable, el grado de madurez de las organizaciones en la aplicación de la Norma ISO/IEC 42001 al ámbito de la ciberseguridad de sistemas de IA. Su intención es eminentemente práctica: proporcionar a CISOs, responsables de IA y órganos de gobierno un espejo razonablemente honesto en el que contemplar su paisaje de riesgos, controles y métricas, sin perder del todo el sentido del humor.

Los resultados se utilizarán para:

- Identificar brechas entre la situación actual y las buenas prácticas sugeridas por ISO/IEC 42001.
- Priorizar acciones de mejora en gobernanza, controles técnicos, telemetría e indicadores.
- Alimentar modelos de cálculo de un Índice Global de Madurez (IGM) y de retorno de la inversión (ROI) en gobierno y seguridad de IA.

2. Población objetivo y roles

La encuesta está dirigida a organizaciones que utilicen IA de forma significativa en procesos de negocio, servicios o infraestructuras críticas, tanto en sector público como privado. Se recomienda que la respuesta sea coordinada entre áreas clave (ciberseguridad, TI, IA/data science, cumplimiento, negocio), aunque la responsabilidad formal pueda recaer en un único rol (típicamente CISO, CIO o Responsable de IA).

3. Estructura general de la encuesta

La encuesta se organiza en diez bloques temáticos:

1. Información general de la organización.
2. Estrategia, gobernanza y alcance del AIMS.
3. Inventario de sistemas de IA y criticidad.
4. Gestión de riesgos de IA y ciberseguridad.
5. Datos, privacidad y seguridad de la información.
6. Seguridad del ciclo de vida de los modelos.
7. Monitorización, métricas y telemetría de IA.
8. Gestión de incidentes y respuesta.
9. Terceros, cadena de suministro y servicios externos.
10. Personas, cultura, indicadores, IGM y ROI.

Cada pregunta se formula en términos de grado de implantación o frecuencia, con opciones de respuesta que permiten una escalación natural desde “no hacemos prácticamente nada” hasta “lo hacemos, lo medimos y lo sufrimos con disciplina”.

4. Escalas de respuesta y puntuación

4.1. Tipos de escala

La mayoría de las preguntas utilizan escalas ordinales de cuatro o cinco niveles, del tipo:

- No implementado / ad hoc.
- Parcialmente implementado / en desarrollo.
- Implementado / maduro.
- Implementado y optimizado / con medición y mejora continua.

En algunos casos se usan escalas de frecuencia (semanal, mensual, anual, ad hoc) o de cobertura (porcentaje de sistemas cubiertos). Estas escalas permiten asignar valores numéricos de forma relativamente directa, sin necesidad de recurrir a alquimia estadística.

4.2. Asignación de puntuaciones

Para el cálculo del Índice Global de Madurez (IGM), se propone asignar a cada respuesta una puntuación entre 0 y 3 (o 0 y 4, según el número de opciones). Por ejemplo:

- 0: No implementado / no se realiza / inexistente.
- 1: Implementación inicial / parcial / ad hoc.
- 2: Implementación sistemática / formalizada.
- 3: Implementación optimizada / integrada en la mejora continua.

En preguntas con cinco opciones, puede utilizarse la escala 0–4. La plantilla de Excel asociará cada opción a un valor numérico y calculará medias ponderadas por bloque y globales.

4.3. Ponderación de bloques

No todos los bloques tienen el mismo peso en términos de riesgo. Desde la perspectiva de la ciberseguridad de IA, suele ser razonable asignar mayor peso a:

- Gestión de riesgos de IA y ciberseguridad.
- Monitorización, métricas y telemetría.
- Gestión de incidentes y respuesta.

La guía propone un esquema inicial de ponderación (que puede adaptarse a cada sector):

- Bloque 2: 10 %.
- Bloque 3: 10 %.
- Bloque 4: 15 %.
- Bloque 5: 10 %.
- Bloque 6: 15 %.
- Bloque 7: 15 %.
- Bloque 8: 10 %.
- Bloque 9: 10 %.
- Bloque 10: 5 %.

El bloque 1 (información general) no puntúa; sirve para contextualizar y segmentar los resultados. Las ponderaciones pueden adaptarse en función de normativa sectorial (financiero, energía, salud, administración pública, etc.).

5. Cálculo del Índice Global de Madurez (IGM)

5.1. Fórmula general

El IGM se define como una media ponderada de las puntuaciones de cada bloque temático:

$$\text{IGM} = 100 \times \Sigma (\text{Puntuación media del bloque} \times \text{Peso del bloque})$$

donde:

- La puntuación media del bloque se calcula como la media aritmética de las puntuaciones de sus preguntas, normalizada a 0–1.
- El peso del bloque es un valor entre 0 y 1 cuya suma total es 1.

El resultado se expresa en una escala de 0 a 100. A efectos interpretativos, puede traducirse en niveles:

- 0–25: Nivel muy bajo – IA experimental sin control.
- 26–50: Nivel bajo – IA en adopción con controles incipientes.
- 51–75: Nivel medio – IA extendida con controles razonables.
- 76–100: Nivel alto – IA integrada con controles maduros y medidos.

5.2. Cálculo de subíndices

Para un análisis más fino, se recomienda calcular subíndices específicos:

- IGM-Gobernanza.
- IGM-Riesgos.
- IGM-Datos.
- IGM-Ciclo de vida.
- IGM-Monitorización.
- IGM-Incidentes.
- IGM-Terceros.
- IGM-Cultura.

Estos subíndices permiten visualizar desequilibrios típicos (por ejemplo, mucha gobernanza en papel y poca telemetría real) y priorizar inversiones de forma menos intuitiva y más basada en evidencias.

6. Medición del ROI de la gestión de IA segura

6.1. Componentes de coste

Los principales costes a considerar incluyen:

- Costes de implantación y operación del AIMS (personas, herramientas, consultoría, certificación).
- Costes de controles adicionales de ciberseguridad específicos de IA (pruebas, telemetría, automatización de respuesta).
- Costes de formación y cambio cultural.

6.2. Componentes de beneficio

En el lado luminoso del balance se sitúan:

- Reducción del número y gravedad de incidentes de seguridad relacionados con IA.
- Reducción de tiempos de detección y respuesta.
- Menor probabilidad de sanciones regulatorias y litigios.
- Protección de reputación y confianza de clientes y ciudadanos.
- Mejora de eficiencia operativa gracias a decisiones de IA más robustas.

6.3. Modelo simplificado de ROI

Un modelo pragmático de ROI puede aproximarse como:

$$\text{ROI} = (\text{Beneficios netos anuales atribuibles al AIMS} - \text{Costes anuales del AIMS}) / \text{Costes anuales del AIMS}$$

La encuesta contribuye a este cálculo identificando:

- Nivel de madurez actual (IGM).
- Evolución temporal (comparando resultados de diferentes años).
- Correlación aproximada entre incrementos del IGM y reducción de incidentes, pérdidas y sanciones.

7. Puesta en marcha de la encuesta

7.1. Modalidad de aplicación

La encuesta puede aplicarse en formato digital (formularios web, herramientas de encuesta) o como parte de talleres facilitados. Para obtener respuestas más honestas, suele ser recomendable:

- Asegurar la confidencialidad de los resultados.
- Explicar que el objetivo es mejorar, no señalar culpables.
- Involucrar a varias áreas en la respuesta.

7.2. Validación y contraste

Es sano contrastar las respuestas con evidencias documentales y, si es posible, con datos objetivos (número real de incidentes, tiempos de respuesta, etc.). Idealmente, la encuesta es el inicio de una conversación, no un fin en sí mismo.

7.3. Periodicidad

Se recomienda repetir la encuesta anualmente para medir evolución. En organizaciones con programas intensivos de IA, una cadencia semestral puede ser razonable.

8. Limitaciones y buen uso

La encuesta no sustituye una auditoría formal ni una certificación ISO/IEC 42001, pero puede ser un excelente radar para detectar zonas de riesgo, incoherencias y sorpresas agradables. La ironía del modelo es que, cuanto más sinceras sean las respuestas, más útiles serán los resultados; maquillar la realidad sólo mejora el IGM en Excel, no la resiliencia real.